

Phishing Detection and Awareness Report

Phishing Attack

How a phishing attack is initiated Phishing is a cyber-attack used by attackers to trick users into clicking malicious links that can be embedded in emails, text messages, and even websites. A user is tricked into clicking this link so that an attacker can gain access to things like passwords, OTP's, usernames, banking information, and other sensitive data. An attacker can also use these links to get a user to download infected files onto a user's computer or smartphone.

Attackers usually disguise themselves as trusted organisations such as Microsoft, Amazon, FNB, or even departments of government. These messages are designed to appear legitimate so that the victim believes the communication is real. Once the victim clicks the malicious link, they may be redirected to a fake login page designed to steal credentials or silently download malware onto their device.

Phishing attacks are commonly initiated through mass email campaigns, but attackers can also target specific individuals in what is known as spear phishing. In spear phishing attacks, the attacker researches the victim beforehand and creates highly

personalised messages to increase the likelihood of success.

Common Phishing Indicators

From address: Phishing emails usually display the name of a trusted organization like Microsoft or Amazon, and yet the sending domain will not be from that organization. Attackers often use domains with slight spelling changes or additional characters in an attempt to trick users into believing the email is legitimate.

Subject: Phishing emails contain a subject that creates a sense of urgency designed to cause the receiver to panic and act and click the malicious link without really thinking. Examples include messages claiming an account will be suspended, a failed payment, or suspicious activity has been detected.

Authentication: Authentication is the action of verifying that a user is who they say they are. Email messages use protocols to authenticate that emails received are sent from a trusted source. Phishing emails usually won't use these authentication mechanisms since the emails would be flagged as untrustworthy.

Suspicious links: Links found inside phishing emails often redirect users to websites unrelated to the claimed sender. Attackers may also shorten links or disguise them to hide the real destination.

Attachments: Phishing emails often contain malicious attachments disguised as invoices, receipts, or important documents. These attachments may contain malware designed to infect a system once opened.

Poor grammar and spelling: Many phishing emails contain grammatical errors, unusual wording, or spelling mistakes. While some attackers create convincing emails, poor writing quality remains a common indicator of phishing attempts.

Email Risk Classification

Safe

An email is considered safe when it passes all the three authentication mechanisms used for ensuring that the sending server is authorised, the email content is cryptographically signed and unaltered, and the domain owner's policy is being enforced. The sender's display name should match the actual sending domain, the email should originate from a

known and trusted mail server, and the content should contain no malicious links or unexpected attachments. An email is considered safe if it is expected and contextually relevant. Safe emails are usually received from trusted contacts or verified organizations and contain information that the receiver is expecting. Even when an email appears safe, users should still remain cautious and verify unusual requests.

Suspicious

An email is considered suspicious when one or more authentication checks return none, softfail, temperror, or permerror, indicating the sender's identity cannot be fully verified. Common indicators include a display name that does not match the actual sending domain, vague or urgent subject lines designed to trick the user to act immediately without thinking, links that redirect to domains unrelated to the claimed sender, and recipients listed as "Undisclosed recipients." A suspicious email is not necessarily malicious but requires one to inspect that email closely before any links are clicked or attachments are opened. Suspicious emails may also request confidential information unexpectedly or contain attachments from unknown senders.

Phishing

An email is considered as phishing when it is unsolicited and typically commercial in nature.

Phishing emails often have no authentication records at all, use disposable or randomly generated sending domains, and are sent to large numbers of receivers at the same time. Phishing is a serious threat because it contains urgent lures, malicious attachments, or links to credential harvesting pages. Phishing emails are specifically designed to steal information, spread malware, or compromise systems. Modern phishing attacks can be highly sophisticated and difficult to identify, especially when attackers imitate trusted brands or internal company communication.

Types of Phishing Attacks

Email phishing: Email phishing is the most common type of phishing attack. Attackers send fraudulent emails pretending to be trusted organisations in order to steal sensitive information.

Spear phishing: Spear phishing targets specific individuals or organisations. These attacks are personalised using information gathered about the victim to make the message appear more convincing.

Smishing: Smishing refers to phishing attacks conducted through SMS or text messages. Attackers send malicious links or fake alerts through mobile messages.

Vishing: Vishing is voice phishing where attackers use phone calls to impersonate legitimate organisations and trick victims into revealing sensitive information.

Clone phishing: Clone phishing involves copying a legitimate email previously sent to a victim and replacing legitimate links or attachments with malicious ones.

Impact of Phishing Attacks

Phishing attacks can result in financial loss, identity theft, data breaches, malware infections, and unauthorised access to systems. Organizations affected by phishing attacks may also experience reputational damage, operational downtime, and legal consequences.

For individuals, compromised credentials can lead to stolen bank accounts, social media accounts, or personal information being exposed online. In businesses, phishing attacks are one of the leading

causes of ransomware infections and security breaches.

Prevention methods

- Do not click on attachments or links found in emails from unverified sources.
- Educate employees about the latest and emerging phishing trends, so that they can recognise them and report them.
- Simulate phishing exercises or campaigns to test the awareness of users and reinforce their training.
- Have clear procedures in place to ensure that employees can report phishing attempts to the IT department or the Security team.
- Use multi-factor authentication (MFA) to add an additional layer of security to accounts.
- Keep operating systems, browsers, and antivirus software updated to protect against known vulnerabilities.

- Verify requests for sensitive information through official communication channels before responding.
- Use email filtering and anti-phishing solutions to detect and block malicious emails before they reach users.

Conclusion

Phishing remains one of the most common and effective cyber-attacks used by threat actors today. Attackers continue to improve their techniques in order to bypass security controls and manipulate users into revealing sensitive information.

Understanding how phishing attacks work, recognising common indicators, and following proper security practices are essential in reducing the risk of compromise.

Both individuals and organisations must remain vigilant and continuously educate users about phishing threats. User awareness, strong authentication mechanisms, and proper reporting procedures all play an important role in defending against phishing attacks and protecting sensitive information.